

Université Ibn Zohr
École Nationale Supérieure de l'Intelligence Artificielle
et Sciences des Données - Taroudant
Filière : Sécurité IT et Confiance Numérique

Projet de fin de module
Audit de la Sécurité des Systèmes d'Information

Audit : ISO 2700x

Simulateur d'Audit de Sécurité

Option 1 : Application Web Interactive

*Application web guidant l'utilisateur à travers un scénario d'audit
de conformité ISO 2700x pour une entreprise fictive*

Réalisé par :	Encadré par :
Id-Moullay Imane	Hasnae L'AMRANI
Essahley Hanane	
Nadarou Youssef	
Maraghi Khaoula	
Laqlib Hajar	
Lahrabli Walid	

ANNÉE UNIVERSITAIRE : 2025/2026

Table des matières

1	Introduction	1
1.1	Importance de la sécurité des systèmes d'information	1
1.2	Rôle des normes ISO/IEC 27001 et ISO/IEC 27002	1
1.2.1	ISO/IEC 27001	1
1.2.2	ISO/IEC 27002	1
1.3	Difficulté d'apprentissage de l'audit de sécurité	1
1.4	Objectifs du projet	2
2	Contexte du projet	3
2.1	Contexte du projet	3
2.2	Objectifs du projet	3
2.3	Livrables attendus	3
2.4	Description générale	3
2.4.1	Type d'application	3
2.4.2	Fonctionnalités principales	3
2.4.3	Description des entreprises auditables	4
2.4.4	Objectifs de l'audit	4
2.5	Méthodologie d'audit implémentée	4
2.5.1	Assistant IA pour la gestion des non-conformités	4
3	Analyse & Conception	5
3.1	Modélisation des données	5
3.1.1	Diagramme de classes (Modèle Conceptuel)	5
3.1.2	Modèle Logique et Modèle Physique (MongoDB)	7
3.2	Diagrammes UML dynamiques	7
3.2.1	Diagramme de cas d'utilisation	7
3.2.2	Diagramme de séquence – Authentification de l'entreprise	8
3.2.3	Diagramme de séquence – Évaluation d'un contrôle par l'auditeur	9
3.3	Environnement de travail et technologies	10
3.3.1	Outils utilisés	10
3.3.2	Technologies utilisées	10
4	Réalisation de projet	12
4.1	Page d'accueil	12
4.2	Authentification	13
4.3	Dashboard de l'auditeur	15
4.4	Dashboard de l'entreprise	15
4.5	Liste des contrôles ISO	16
4.6	Évaluation des contrôles	16
4.7	Génération de rapport PDF	17

Conclusion	17
Conclusion générale	18

Liste des figures

3.1	Diagramme de classes – Modèle conceptuel des données	6
3.2	Diagramme de cas d'utilisation	7
3.3	Diagramme de séquence – Authentification entreprise	8
3.4	Diagramme de séquence – Évaluation d'un contrôle (version simplifiée)	9
3.5	Visual Studio Code – éditeur principal	10
3.6	MongoDB – base de données NoSQL	10
3.7	Express.js – framework backend pour l'API REST	10
3.8	React.js – bibliothèque frontend pour l'interface utilisateur	10
3.9	Node.js – environnement d'exécution JavaScript	11
4.1	Page d'accueil de l'auditeur avec progression et accès rapide	12
4.2	Vue d'accueil alternative avec les normes ISO mises en avant	13
4.3	Page d'accueil côté entreprise : suivi de la progression et simulateur	13
4.4	Page de sélection du rôle (auditeur ou entreprise)	14
4.5	Formulaire de connexion pour l'entreprise (email et mot de passe)	14
4.6	Connexion par code d'accès reçu par email	15
4.7	Dashboard de l'auditeur avec score pondéré, progression et détails entreprise	15
4.8	Dashboard de l'entreprise : vue d'ensemble des résultats	16
4.9	Liste des contrôles ISO avec statistiques de conformité	16
4.10	Génération du rapport PDF côté auditeur	17
4.11	Vue du rapport final pour l'entreprise avec détails et taux de conformité	17

Chapitre 1

Introduction

1.1 Importance de la sécurité des systèmes d'information

La sécurité des systèmes d'information (SSI) occupe aujourd'hui une place centrale dans la stratégie des organisations. Face à l'explosion du volume de données et à l'évolution croissante des cyberattaques, garantir la confidentialité, l'intégrité et la disponibilité de l'information est devenu un enjeu stratégique de premier ordre. Les incidents de sécurité — qu'ils prennent la forme de fuites de données, de rançongiciels ou d'attaques par déni de service — engendrent des conséquences financières, juridiques et réputationnelles considérables. Dans ce contexte, l'audit de sécurité se présente comme un mécanisme essentiel permettant de vérifier l'adéquation et l'efficacité des mesures de protection mises en place.

1.2 Rôle des normes ISO/IEC 27001 et ISO/IEC 27002

Les normes ISO 27000 sont des standards internationaux les plus reconnus en matière de gestion de la sécurité de l'information. Elles aident les organisations à protéger leurs informations sensibles en fournissant un cadre complet et cohérent pour établir, implémenter, maintenir et améliorer un Système de Management de la Sécurité de l'Information (SMSI). Les normes ISO 27001, 27002 et 27005 sont trois des plus importantes dans cette famille.

1.2.1 ISO/IEC 27001

L'ISO 27001 définit les exigences pour établir, mettre en œuvre, maintenir et améliorer un SMSI. Elle spécifie les processus et les contrôles nécessaires pour gérer les risques liés à la sécurité de l'information. Les organisations certifiées ISO 27001 démontrent leur engagement envers la sécurité de l'information.

1.2.2 ISO/IEC 27002

L'ISO 27002 complète l'ISO 27001 en fournissant des lignes directrices pour les mesures de sécurité. Elle détaille les meilleures pratiques pour la gestion de la sécurité de l'information. Les organisations utilisent l'ISO 27002 pour sélectionner et mettre en œuvre des contrôles de sécurité efficaces.

1.3 Difficulté d'apprentissage de l'audit de sécurité

L'apprentissage de l'audit de conformité ISO 2700x se heurte à plusieurs obstacles dans un contexte pédagogique traditionnel. La complexité et le volume des référentiels normatifs constituent un frein important : les normes ISO 27001 et 27002 comportent des dizaines de

clauses et de contrôles dont la compréhension approfondie requiert un effort considérable, souvent difficile à maintenir sans mise en application concrète. De plus, l'accès à des environnements de production réels à des fins pédagogiques est généralement impossible pour des raisons de confidentialité et de sécurité.

1.4 Objectifs du projet

Ce projet vise à concevoir et développer une application web interactive constituant un simulateur complet d'audit de conformité ISO 2700x. Ce simulateur guidera l'utilisateur à travers les différentes étapes d'un audit réel appliqué à une entreprise fictive, en lui proposant un environnement immersif et réaliste. Au-delà de l'aspect applicatif, il poursuit un objectif pédagogique fondamental : permettre aux apprenants de s'approprier concrètement les concepts, la terminologie et la logique des normes ISO 2700x.

Chapitre 2

Contexte du projet

2.1 Contexte du projet

L'audit de sécurité des systèmes d'information est une discipline cruciale pour évaluer la conformité et l'efficacité des mesures de sécurité. Les référentiels comme ISO 27001 (SMSI), ISO 27002 (bonnes pratiques) et ISO 27005 (gestion des risques) sont des standards internationaux que les entreprises cherchent à respecter.

2.2 Objectifs du projet

- Développer une application web interactive de simulation d'audit.
- Permettre à l'utilisateur de collecter des preuves, évaluer des contrôles et documenter des non-conformités.
- Intégrer une assistance IA pour proposer des plans d'action.

2.3 Livrables attendus

1. Application fonctionnelle (simulateur d'audit)
2. Documentation technique complète
3. Rapport de projet
4. Présentation orale avec démonstration

2.4 Description générale

2.4.1 Type d'application

L'application développée est une plateforme web d'audit de sécurité des systèmes d'information, permettant d'évaluer la conformité d'une organisation selon les normes ISO 27001 et ISO 27002. Elle repose sur une architecture :

- Frontend : Interface utilisateur interactive (gestion des audits)
- Backend : API REST en Node.js / Express
- Base de données : MongoDB (via Mongoose)

2.4.2 Fonctionnalités principales

- Création et configuration d'un scénario d'audit adapté au contexte de l'entreprise.
- Consultation des contrôles ISO à évaluer.

- Évaluation des contrôles avec statut : Conforme / Partiellement conforme / Non conforme.
- Justification détaillée des décisions et identification des risques (probabilité et impact).
- Visualisation des résultats via un dashboard : scores globaux et pondérés, statistiques de conformité.
- Génération automatique d'un rapport PDF.

2.4.3 Description des entreprises auditable

L'application permet à trois entreprises fictives (TechCorp, FinancePlus, HealthData) de se connecter pour fournir leurs informations. Chaque entreprise saisit son contexte organisationnel, son infrastructure et ses données sensibles.

2.4.4 Objectifs de l'audit

Évaluer la conformité des entreprises aux normes ISO 27001 et 27002 en couvrant :

- Systèmes applicatifs et services internes
- Contrôles d'accès utilisateurs
- Gestion des données et confidentialité
- Procédures et politiques de sécurité

2.5 Méthodologie d'audit implémentée

La méthodologie suit les étapes : planification, collecte de preuves, évaluation des contrôles, analyse des risques, génération du rapport. L'assistant IA intervient pour les non-conformités.

2.5.1 Assistant IA pour la gestion des non-conformités

Lorsqu'un auditeur évalue un contrôle et lui attribue le statut « Non conforme », l'assistant IA est automatiquement sollicité. Voici comment il fonctionne :

- **Déclenchement** : Dès que le statut « Non conforme » est sélectionné, l'application envoie les données de l'évaluation (contrôle concerné, justification, gravité, probabilité) à l'API Google Gemini.
- **Analyse** : L'IA analyse la non-conformité en se basant sur les exigences de la norme ISO 27002 et le contexte de l'entreprise.
- **Proposition de plan d'action** : L'IA génère un plan d'action structuré comprenant la description de l'écart constaté, les actions correctives prioritaires, un échéancier suggéré (court, moyen, long terme), la désignation d'un responsable proposé et des indicateurs de suivi.
- **Validation par l'auditeur** : L'auditeur peut modifier, enrichir ou valider le plan d'action proposé avant de le sauvegarder dans l'évaluation.
- **Suivi** : Le plan d'action est associé à l'évaluation et peut être consulté dans le dashboard ainsi que dans le rapport final PDF.

Cette fonctionnalité permet d'offrir une assistance intelligente et gain de temps à l'auditeur, tout en garantissant que les non-conformités soient traitées de manière systématique et conforme aux bonnes pratiques ISO.

Chapitre 3

Analyse & Conception

Ce chapitre marque une étape cruciale de notre projet en se concentrant sur la phase d'**analyse et de spécification des besoins**. Son objectif est de définir de manière précise et structurée les fonctionnalités et la structure des données de notre simulateur d'audit de sécurité.

Nous commencerons par la **modélisation des données** à l'aide d'un diagramme de classes UML, qui constitue notre Modèle Conceptuel de Données (MCD). Ensuite, nous présenterons les diagrammes dynamiques : cas d'utilisation et diagrammes de séquence. Enfin, nous décrirons l'environnement technique et les technologies utilisées.

3.1 Modélisation des données

3.1.1 Diagramme de classes (Modèle Conceptuel)

Le diagramme de classes ci-dessous (Figure 3.1) représente les principales entités du système, leurs attributs et leurs relations. Il s'agit de notre Modèle Conceptuel de Données (MCD).

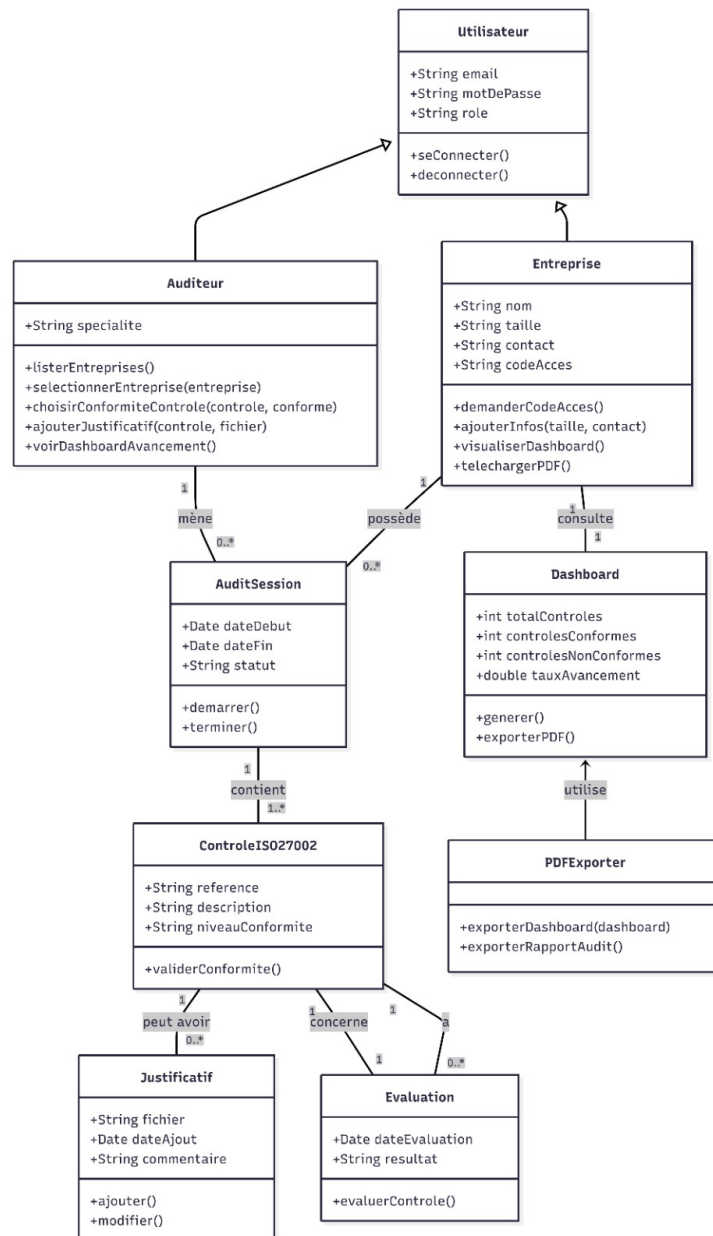


FIGURE 3.1 – Diagramme de classes – Modèle conceptuel des données

Entités principales :

- **Utilisateur** : attributs communs (email, motDePasse, rôle). Méthodes : `seConnecter()`, `deconnecter()`.
- **Auditeur** : hérite de Utilisateur. Spécialité. Actions : lister les entreprises, sélectionner une entreprise, évaluer les contrôles, ajouter des justificatifs, visualiser le tableau de bord.
- **Entreprise** : hérite de Utilisateur. Attributs : nom, taille, contact, codeAcces. Actions : demander un code d'accès, ajouter ses informations, visualiser son tableau de bord, télécharger le rapport PDF.
- **ControleISO27002** : référence, description, niveauConformite, méthode `validerConformite()`.
- **Evaluation** : dateEvaluation, resultat, méthode `evaluerControle()`.
- **Justificatif** : fichier, dateAjout, commentaire, méthodes `ajouter()`, `modifier()`.
- **PDFExporter** : exporte le tableau de bord ou le rapport d'audit.
- **Conseil** : contient les informations globales de l'audit (dates, statut, nombres de contrôles

conformes/non conformes, taux d'avancement).

Les relations entre ces entités sont explicitées sur le diagramme (héritage, associations, cardinalités).

3.1.2 Modèle Logique et Modèle Physique (MongoDB)

Notre base de données étant **MongoDB** (NoSQL), le modèle logique se traduit par des collections. Voici les principales collections et leurs champs :

- **users** : { _id, name, email, password, role (auditor/company_admin), companyId }
- **companies** : { _id, name, sector, size, industry, contactEmail, auditProgress }
- **controls** : { _id, code, title, description, objective, category, companyId }
- **evaluations** : { _id, controlId, companyId, status, justification, severity, probability, riskLevel, recommendation }
- **evidences** : { _id, controlId, type, content }
- **scenarios** : { _id, name, sector, size, keySystems, securityContext, auditObjective, companyId }

Le modèle physique est implémenté avec **Mongoose** (schémas et validation). Les références entre collections sont gérées via **ObjectId**.

3.2 Diagrammes UML dynamiques

3.2.1 Diagramme de cas d'utilisation

La Figure 3.2 présente les interactions entre les acteurs (**Auditeur** et **Entreprise Admin**) et les fonctionnalités du simulateur.

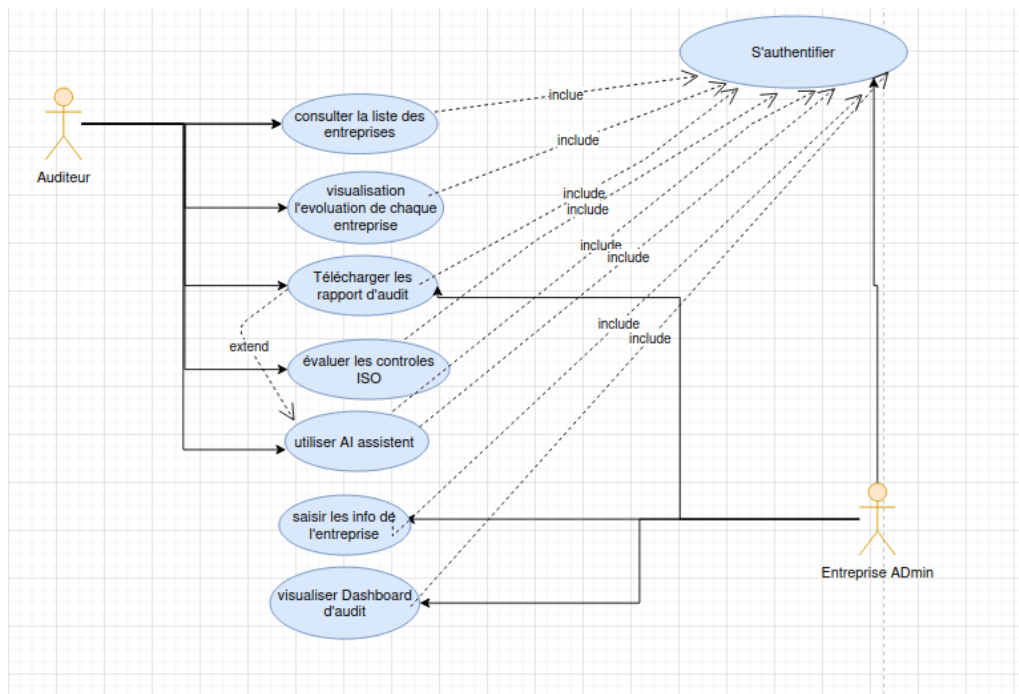


FIGURE 3.2 – Diagramme de cas d'utilisation

Principaux cas d'utilisation :

- **Auditeur** : s'authentifier, consulter la liste des entreprises, visualiser les évaluations, télécharger les rapports, évaluer les contrôles (avec inclusion de la justification et de l'évaluation des risques), utiliser l'assistant IA, saisir les informations de l'entreprise (si nécessaire) et visualiser le tableau de bord.
- **Entreprise** : s'authentifier, saisir ses informations, consulter son tableau de bord, télécharger son rapport.

Les relations « include » et « extend » sont indiquées (par exemple, l'évaluation des contrôles inclut la justification et l'évaluation des risques; l'assistant IA étend le traitement des non-conformités).

3.2.2 Diagramme de séquence – Authentification de l'entreprise

La Figure 3.3 détaille le processus d'inscription et de connexion pour une entreprise.

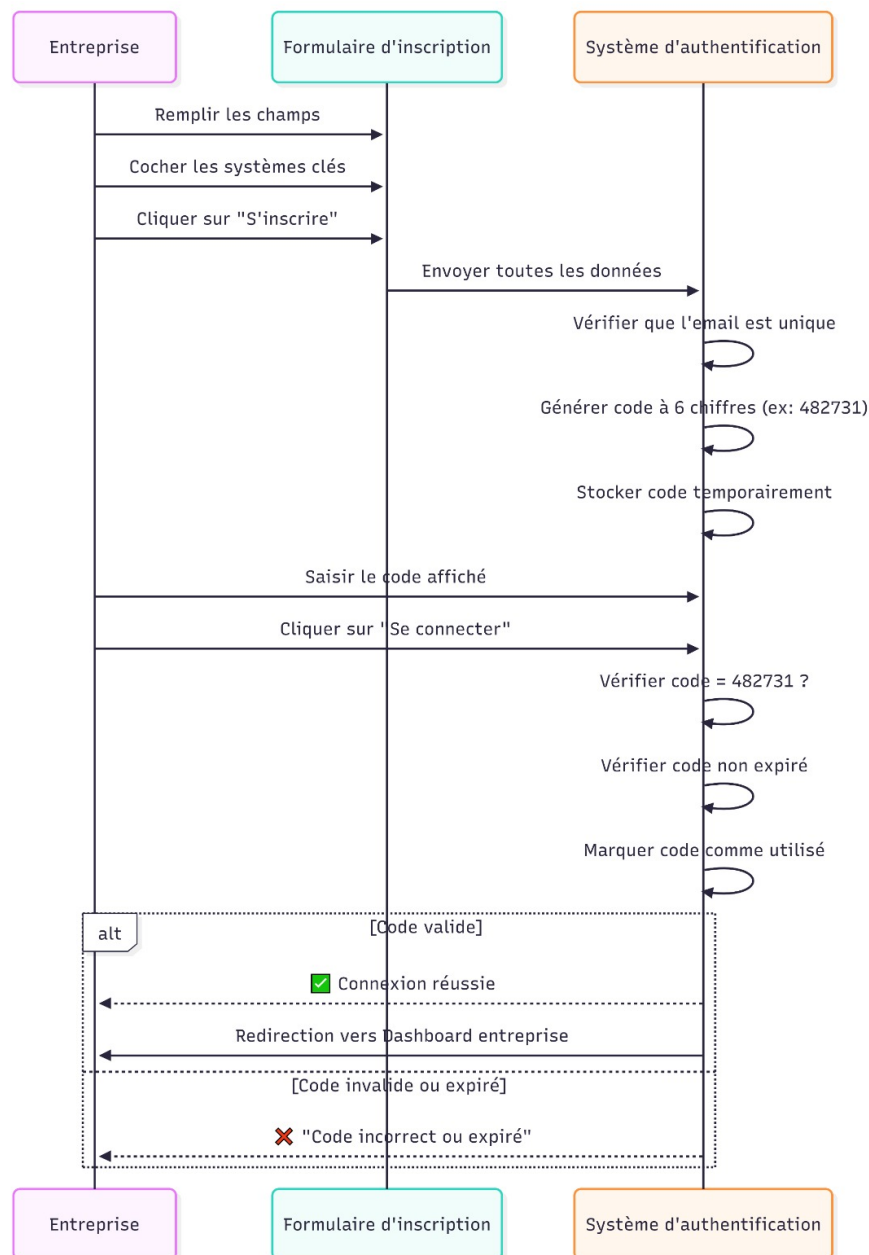


FIGURE 3.3 – Diagramme de séquence – Authentification entreprise

L'entreprise remplit ses informations (nom, taille, contact, systèmes clés). Le système génère un code d'accès à 6 chiffres, stocké temporairement. L'entreprise saisit ce code ; s'il est valide et non expiré, la connexion est réussie et elle est redirigée vers son tableau de bord. En cas d'échec, un message d'erreur est affiché.

3.2.3 Diagramme de séquence – Évaluation d'un contrôle par l'auditeur

La Figure 3.4 illustre l'action centrale de l'auditeur : évaluer un contrôle ISO 27002.

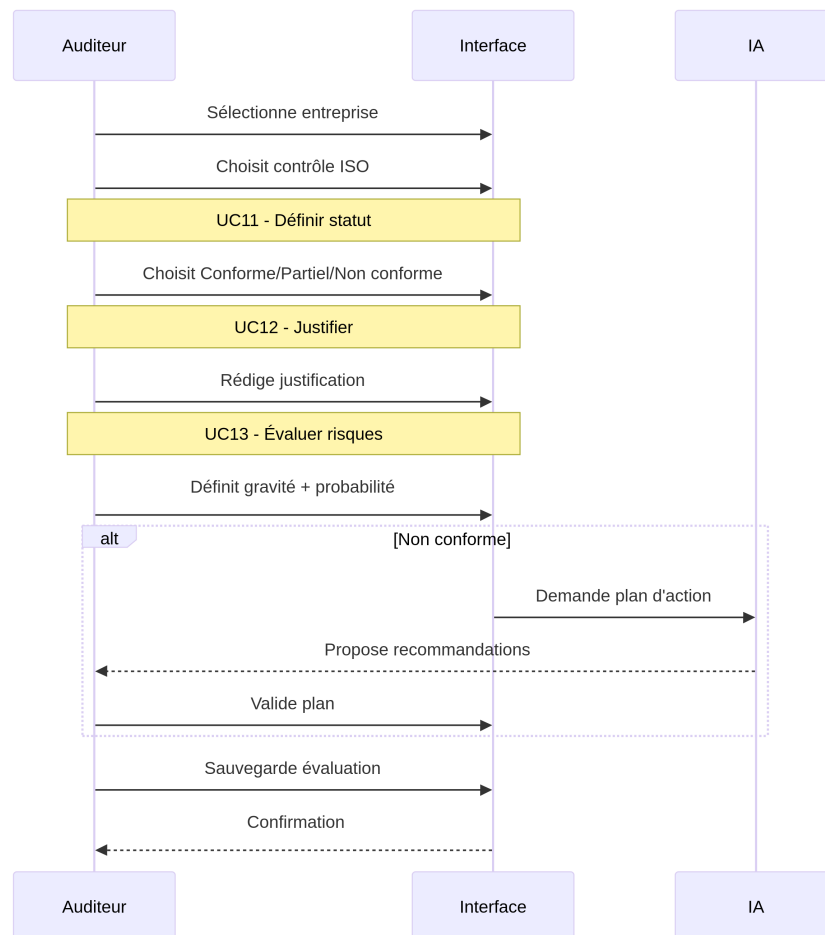


FIGURE 3.4 – Diagramme de séquence – Évaluation d'un contrôle (version simplifiée)

L'auditeur sélectionne une entreprise puis un contrôle. Il définit le statut (Conforme / Partiellement conforme / Non conforme), rédige une justification et évalue la gravité et la probabilité des risques. Si le statut est « Non conforme », l'assistant IA est sollicité pour proposer un plan d'action ; l'auditeur valide ou modifie ce plan. Enfin, l'évaluation est sauvegardée et une confirmation est affichée.

3.3 Environnement de travail et technologies

3.3.1 Outils utilisés

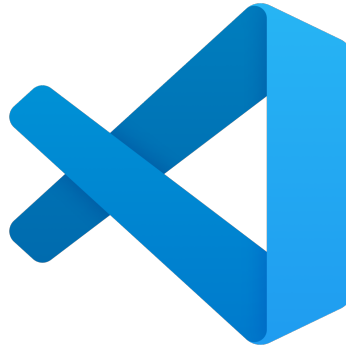


FIGURE 3.5 – Visual Studio Code – éditeur principal

- **Visual Studio Code** : éditeur de code source avec extensions pour React, Node.js et Mermaid.
- **MongoDB Compass** : interface graphique pour administrer la base de données.
- **Git** : gestion de versions.
- **Mermaid / Draw.io** : création des diagrammes UML.

3.3.2 Technologies utilisées

Notre application repose sur la stack **MERN** (MongoDB, Express.js, React.js, Node.js). Chaque technologie est présentée ci-dessous.



FIGURE 3.6 – MongoDB – base de données NoSQL



ESDT ENMANUEL ASOUJO

FIGURE 3.7 – Express.js – framework backend pour l'API REST



ESDT ENMANUEL ASOUJO

FIGURE 3.8 – React.js – bibliothèque frontend pour l'interface utilisateur



FIGURE 3.9 – Node.js – environnement d’exécution JavaScript

- **JWT** + **bcrypt** : authentification et sécurisation des mots de passe.
- **jsPDF** / **html2canvas** : génération de rapports PDF côté client.

Conclusion

Ce chapitre a posé les bases de la conception de notre simulateur d’audit ISO 2700x. Nous avons défini le modèle de données via un diagramme de classes, décrit les cas d’utilisation et les interactions clés à l’aide de diagrammes de séquence. Les choix technologiques (MERN, IA, génération PDF) ont été justifiés. Cette analyse nous permet d’aborder la phase de réalisation dans les meilleures conditions.

Chapitre 4

Réalisation de projet

Dans ce chapitre, nous présentons les principales interfaces de notre simulateur d'audit ISO 2700x. Les captures d'écran ci-dessous illustrent le flux complet, de la connexion à la génération du rapport.

4.1 Page d'accueil

La page d'accueil offre un aperçu général du simulateur. Elle présente les entreprises disponibles à auditer, la progression globale et un accès rapide aux différentes sections (contrôles, tableau de bord, rapport). Deux vues sont disponibles : une pour l'auditeur (Figure 4.1) et une pour l'entreprise (Figure 4.3).

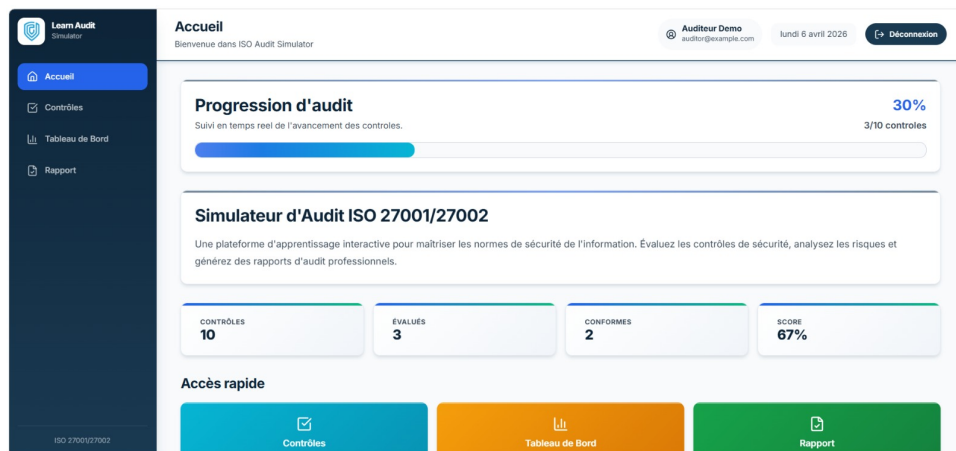


FIGURE 4.1 – Page d'accueil de l'auditeur avec progression et accès rapide



FIGURE 4.2 – Vue d'accueil alternative avec les normes ISO mises en avant

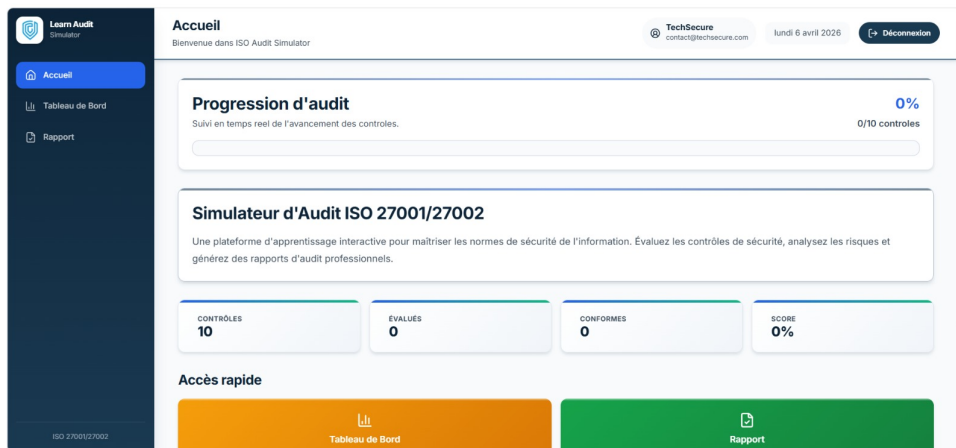


FIGURE 4.3 – Page d'accueil côté entreprise : suivi de la progression et simulateur

4.2 Authentification

Le système gère deux types d'utilisateurs : l'auditeur et l'entreprise. La Figure 4.4 présente le choix du rôle. Les Figures 4.5 et 4.6 montrent respectivement la connexion par email/mot de passe et par code d'accès (généré lors de l'inscription). L'authentification repose sur JWT pour sécuriser les échanges.

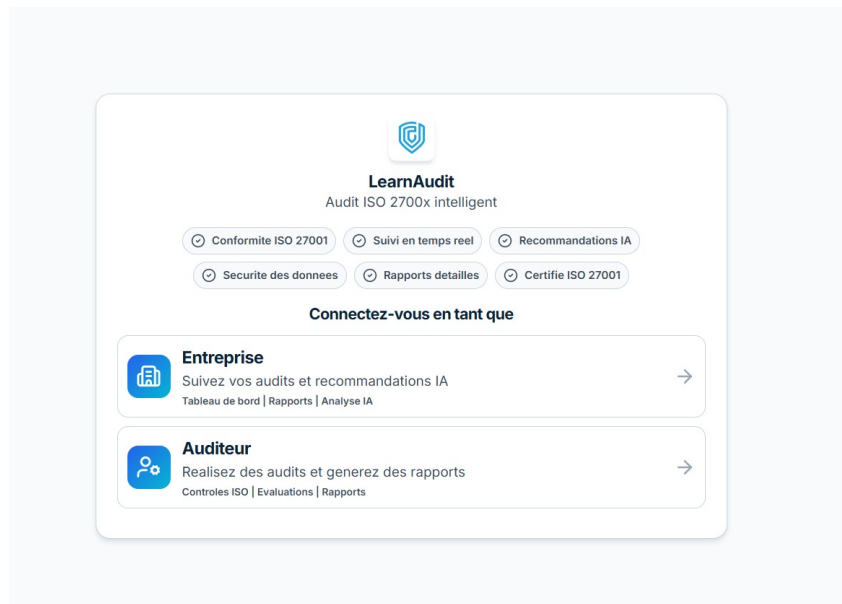


FIGURE 4.4 – Page de sélection du rôle (auditeur ou entreprise)

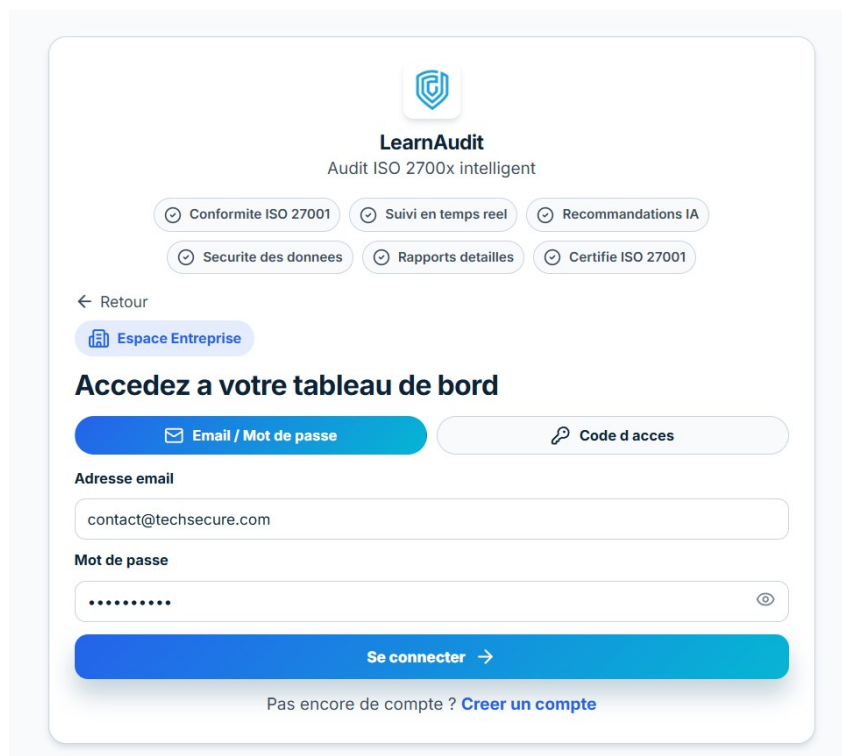


FIGURE 4.5 – Formulaire de connexion pour l'entreprise (email et mot de passe)

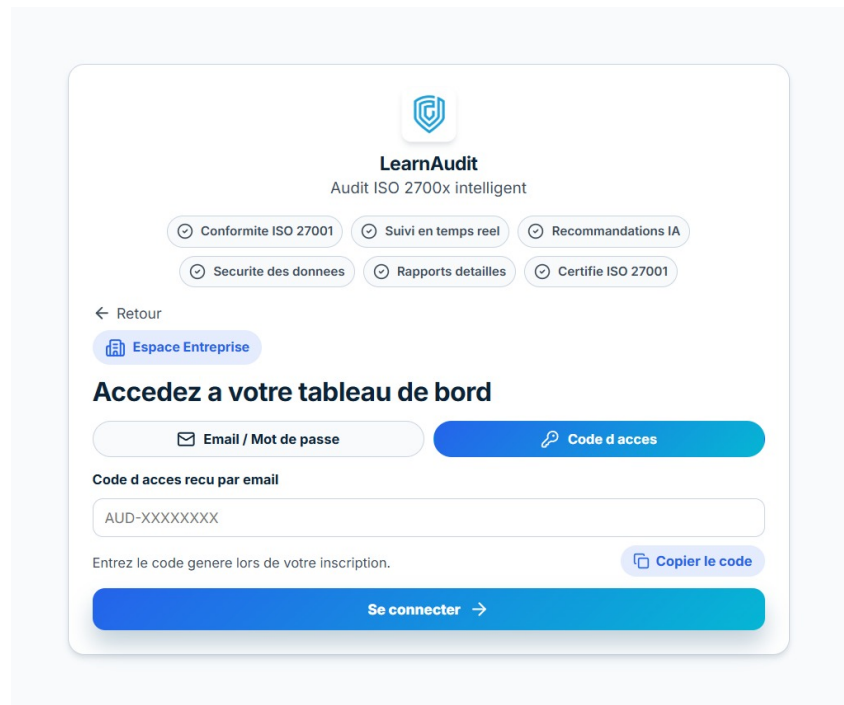


FIGURE 4.6 – Connexion par code d’accès reçu par email

4.3 Dashboard de l’auditeur

Après connexion, l’auditeur accède à un tableau de bord global (Figure 4.7) qui présente une synthèse des audits en cours : score global, progression, répartition des contrôles (conformes, partiellement conformes, non conformes). Il peut également visualiser les informations de l’entreprise auditée.

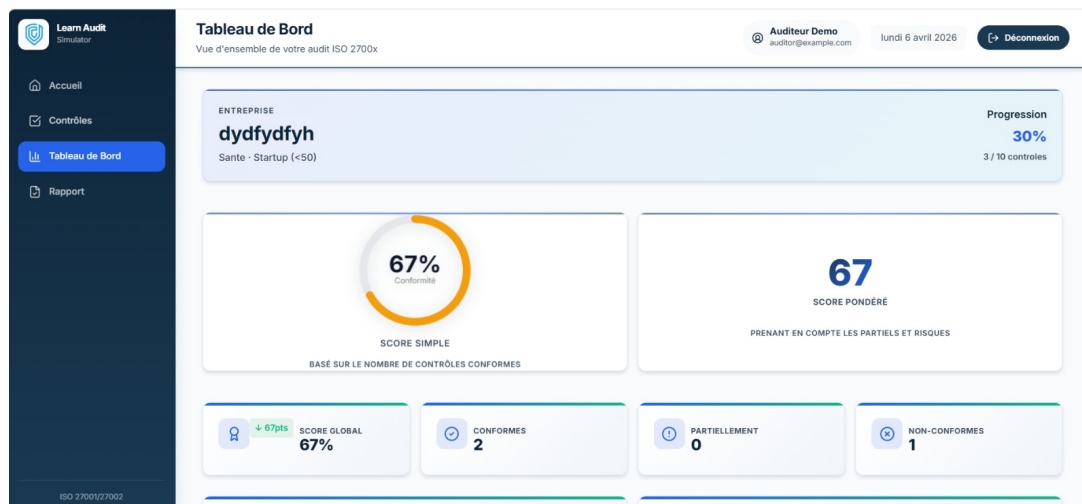


FIGURE 4.7 – Dashboard de l’auditeur avec score pondéré, progression et détails entreprise

4.4 Dashboard de l’entreprise

L’entreprise dispose d’un tableau de bord personnel (Figure 4.8) lui permettant de suivre l’avancement de son propre audit : nombre de contrôles évalués, conformité, score global et répartition des résultats.

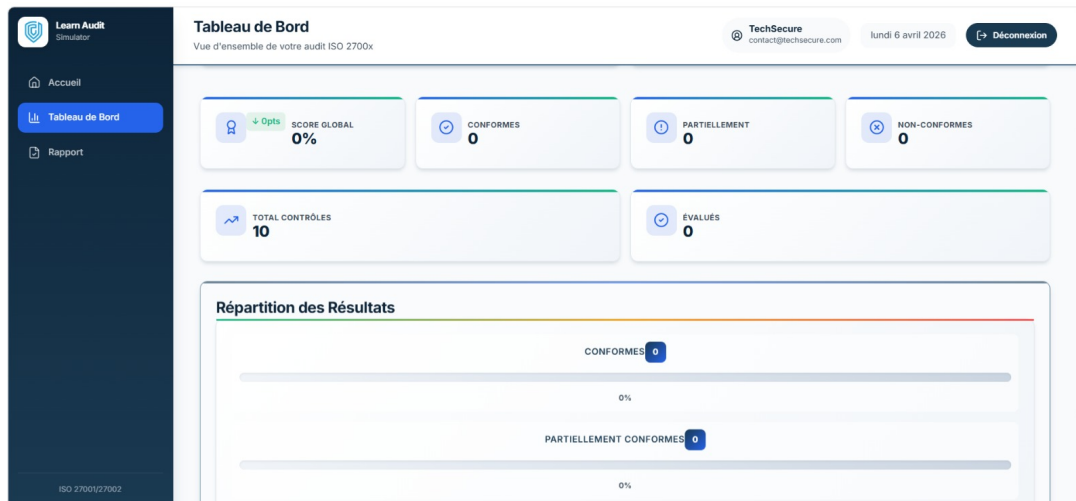


FIGURE 4.8 – Dashboard de l'entreprise : vue d'ensemble des résultats

4.5 Liste des contrôles ISO

La page des contrôles (Figure 4.9) affiche l'ensemble des 45 contrôles ISO 27002 à évaluer. Pour chaque contrôle, on visualise son code, son titre, sa catégorie, et un indicateur de conformité (conforme, partiel, non conforme). L'auditeur peut filtrer, rechercher et accéder au détail de chaque contrôle.

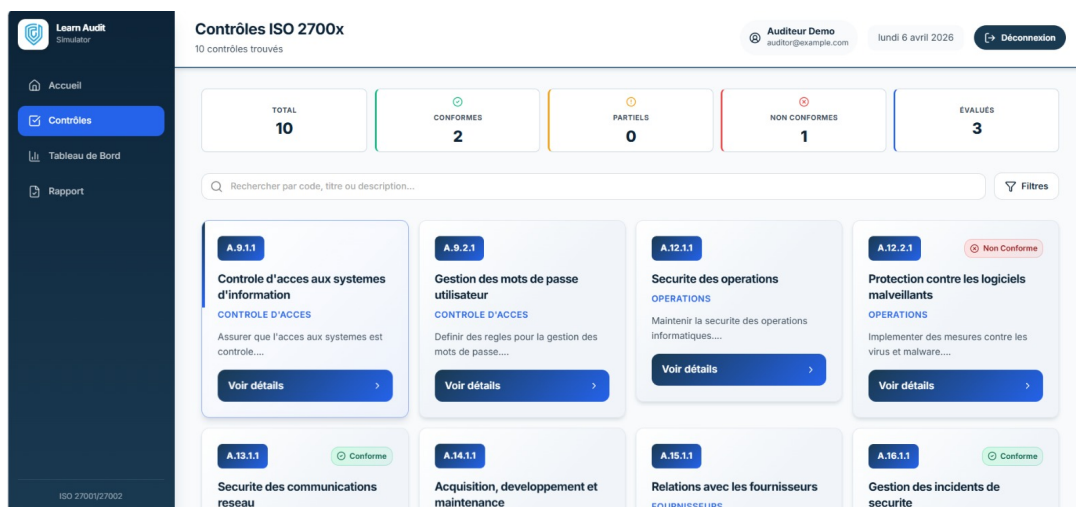


FIGURE 4.9 – Liste des contrôles ISO avec statistiques de conformité

4.6 Évaluation des contrôles

En cliquant sur un contrôle, l'auditeur accède à un formulaire d'évaluation (non illustré ici, mais similaire aux maquettes). Il peut définir le statut (Conforme / Partiellement conforme / Non conforme), rédiger une justification, évaluer la gravité et la probabilité des risques, et attacher des preuves. En cas de non-conformité, l'assistant IA est sollicité pour proposer un plan d'action.

4.7 Génération de rapport PDF

L'auditeur peut générer un rapport d'audit complet au format PDF (Figure 4.10). Ce rapport reprend les informations de l'entreprise, les résultats détaillés par contrôle, les justifications, les analyses de risques et le plan d'action. L'entreprise peut également télécharger son propre rapport (Figure 4.11).

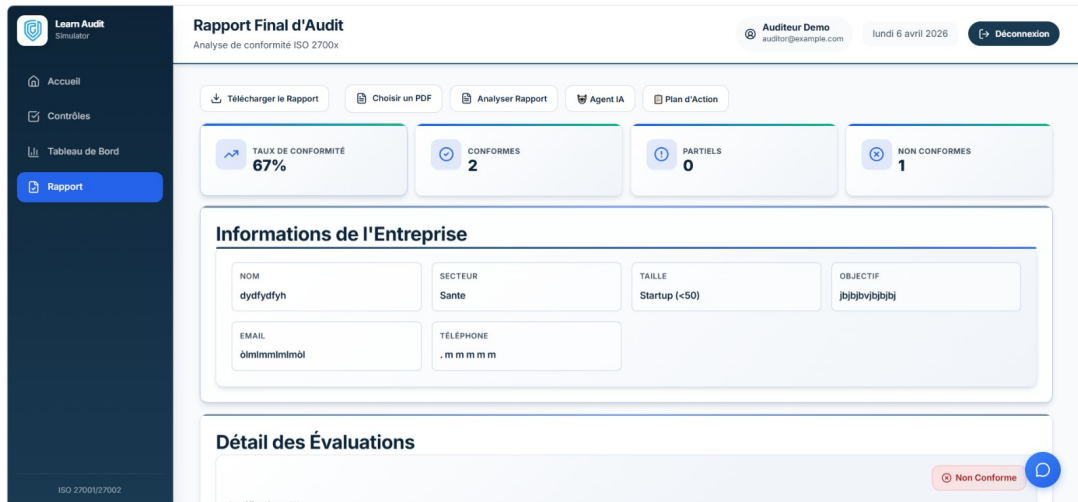


FIGURE 4.10 – Génération du rapport PDF côté auditeur

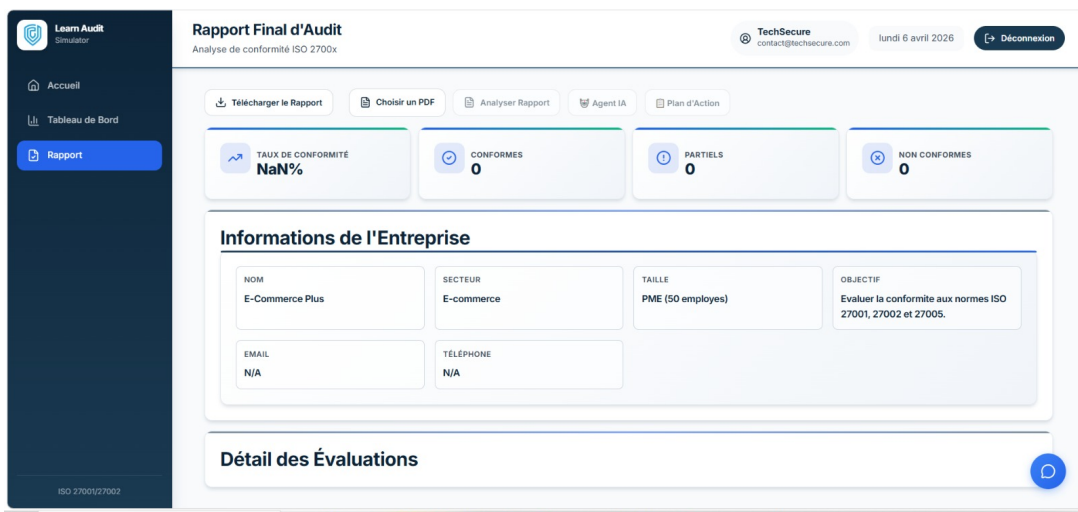


FIGURE 4.11 – Vue du rapport final pour l'entreprise avec détails et taux de conformité

Conclusion

Les interfaces développées offrent une expérience utilisateur fluide et pédagogique. Elles couvrent l'intégralité du cycle d'audit : authentification, suivi de progression, évaluation des contrôles, visualisation des résultats et génération de rapports. L'intégration de l'assistant IA renforce l'aide à la décision pour traiter les non-conformités.

Conclusion générale

Ce projet a abouti au développement d'un simulateur d'audit ISO 2700x complet, couvrant l'authentification, l'évaluation des contrôles, la gestion des risques, le tableau de bord et la génération de rapports PDF, avec une assistance IA pour les non-conformités. Les objectifs pédagogiques et techniques ont été atteints, malgré des difficultés de gestion d'espace disque et de quotas API. Cette expérience a renforcé nos compétences en MERN, en cybersécurité et en rédaction technique. Des perspectives comme le mode collaboratif ou une application mobile restent ouvertes pour enrichir l'outil.